

Cybersecurity in the Age of Agentic AI

A Financial-Sector Governance Perspective for Master of Finance Students and Executive Decision-Makers

Alejandro Reynoso

Pedagogical disclaimer. This document is prepared exclusively for educational and pedagogical purposes. It is intended to support discussion of cybersecurity, operational risk, governance, and control architecture in financial institutions. It does not provide operational instructions for compromising systems, does not constitute cybersecurity testing guidance for production environments, and should not be interpreted as legal, regulatory, investment, technology, or security advice. Any real-world implementation should be designed, reviewed, tested, and authorized by appropriately qualified professionals under the institution's applicable policies and regulatory framework.

Executive Summary

Agentic artificial intelligence changes cybersecurity in finance because it changes the application itself. Traditional software applies pre-specified rules to data. Agentic systems interpret language, form judgments, call tools, consult external information, maintain state, and may initiate actions. The security question is therefore no longer only whether an attacker can enter a system, but whether an attacker can alter the information, context, memory, or instructions that shape the system's decisions [4, 9, 10].

For financial institutions, this is fundamental. A financial application is an economic decision mechanism: prices become valuations, risk estimates become limits, payment instructions move cash, and trading signals become positions. Integrity can therefore be more consequential than confidentiality alone. Observing a price is a privacy breach; changing it can distort NAVs, collateral, risk measures, and transactions.

Agentic AI also creates a two-sided threat landscape. It can lower the cost of adversarial reconnaissance and attack orchestration while institutions simultaneously introduce new vulnerabilities by connecting LLM-driven agents to research, operations, payments, risk, and investment workflows. The central governance implication is straightforward: **separate operational intelligence from operational authority**. AI may analyze and propose, but material actions should remain bounded by deterministic controls, explicit authorization, least-privilege credentials, independent reconciliation, and meaningful human or multi-party approval [1, 2, 3].

Five conclusions for senior financial professionals

1. Protect the **integrity** of financial data and decision chains as aggressively as confidentiality.
2. Treat all external natural-language content as potentially **untrusted input**.
3. Assume that model-level defenses will sometimes fail; put critical limits **outside the model**.
4. Tie AI risk limits to the agent's **operational authority**, not merely to model capability.
5. Design for **containment, revocation, reconciliation, and recovery**, not for perfect prevention.

1 Why Cybersecurity Changes When Software Becomes Agentic

Traditional cybersecurity categories—unauthorized access, malware, credential theft, data exfiltration, denial of service, and transactional manipulation—remain relevant. What changes with agentic AI is the pathway through which a system can be influenced.

Conventional applications maintain an explicit distinction between executable instructions and stored data. LLM-based systems do not preserve that boundary in the same way because natural language is simultaneously information and instruction. A sentence may be interpreted as evidence, procedure, request, prohibition, or command; the distinction is inferred rather than mechanically guaranteed.

That becomes financially significant when an agent sits between information and action. Research agents read external material, valuation agents interpret market commentary, treasury agents analyze liquidity, and compliance agents review documentation. More autonomous systems may also call tools, update records, submit orders, or communicate externally.

The resulting chain can be represented as:

Inputs → Model Interpretation → Tool Use / Decision → Financial Action → Economic Consequence.

Security therefore becomes inseparable from financial control. If an adversary can corrupt any part of this chain—the inputs, the model’s context, its memory, its permissions, or the downstream authorization process—the output may remain technically valid while becoming economically wrong.

That is why boards and senior executives should resist treating agentic cybersecurity as a narrow technology problem. It is simultaneously an issue of operational risk, model risk, internal control, market conduct, fiduciary responsibility, third-party risk, and business continuity [6, 7, 8].

2 The Integrity Mandate: Why Modification Can Matter More Than Theft

Confidentiality remains essential in finance. Customer information, trading strategies, credentials, proprietary models, and deal information all require protection. Yet many of the most consequential AI-era scenarios are integrity failures rather than secrecy failures.

Consider a simple bond price of 98.25. Unauthorized observation is a confidentiality event. Unauthorized modification to 108.25 is an integrity event. The second case may contaminate portfolio valuation, collateral calculations, risk reports, limit monitoring, client statements, tax records, and trading decisions. The application may function exactly as designed and still produce a damaging outcome because the input state is false.

The same logic applies to interest-rate curves, volatility surfaces, counterparty reference data, beneficiary instructions, risk limits, model parameters, portfolio positions, approved vendor lists, and settlement details. Financial applications convert these values into economically meaningful consequences. The security objective is therefore not simply to prevent unauthorized access. It is to preserve the authenticity, provenance, authorization status, and consistency of the financial state.

For agentic AI, this produces a broader security perimeter built around five linked concepts:

- **Confidentiality:** who is allowed to see the information?
- **Integrity:** has the information been altered?
- **Availability:** is the system usable when economically required?
- **Provenance:** where did the information originate and how did it arrive?
- **Authorization:** who—human or machine—is permitted to act on it?

For investment professionals, the practical lesson is that cybersecurity increasingly resembles the design of a control system around a decision engine. The challenge is to preserve a trusted state while information is continuously imported, interpreted, transformed, and acted upon.

3 The Two-Sided AI Threat Landscape

The first side of the problem is familiar: AI can improve attacker productivity. Reconnaissance, code review, document analysis, vulnerability hypothesis generation, social-engineering preparation, and testing can be accelerated or parallelized. The management issue is not an all-powerful adversary; it is a lower marginal cost of attacking many targets and a faster adaptation cycle.

The second side is newer. Institutions are themselves deploying applications that interpret language

probabilistically and connect to operational tools. This creates exploit classes that do not map neatly to conventional software bugs.

A central example is **indirect prompt injection**. Adversarial instructions may be embedded in a document, email, website, market report, or other content that an agent is expected to read. If untrusted content is not effectively separated from authorized instructions, passive information can influence subsequent behavior. This is best understood as social engineering for machines: the same linguistic channel carries both content and instruction [9, 4].

Persistent memory increases the risk. A false beneficiary classification, altered limit, or fabricated relationship can survive across workflows, creating **memory poisoning**. Multi-agent architectures add another layer: compromised conclusions may propagate from research to risk to execution if downstream agents treat upstream messages as authoritative. Machine-to-machine communication does not, by itself, establish trust [4, 10].

4 Authority Is the Variable That Determines the Loss Distribution

A useful way to think about AI cyber risk is:

$$\text{Cyber Consequence} = f(\text{Manipulation, Operational Authority, Controls}).$$

Model capability matters, but authority determines the economic blast radius. The same compromised model can produce very different consequences depending on what it is allowed to do.

Architecture	Operational Authority	Typical Consequence Profile
Human advisor	Read, summarize, recommend	Misinformation or flawed analysis reaches a human reviewer; losses depend on whether the error is detected before action.
Automated proposer	Propose actions, but execution is gated	Risk is bounded if deterministic checks, thresholds, and approvals are genuinely independent of the model.
Autonomous API agent	Direct write or transaction access	Manipulation can convert immediately into database changes, orders, payments, or persistent memory corruption.

Human-in-the-loop designs are therefore useful but insufficient. Dramatic manipulation is easier to catch than a subtle change that remains within a reviewer's intuitive range. Repeated approvals, time pressure, confirmation bias, and alert fatigue can turn nominal oversight into rubber-stamping.

The quality of human control matters more than the existence of an approval button. Reviewers should see the source, proposed action, deviation from the authenticated state, tools used, and expected economic effect. Material deviations should require escalation or dual authorization.

5 Why Deterministic Security Gates Must Sit Outside the Model

LLMs are probabilistic systems. Even when highly capable, they cannot provide a mathematical guarantee that an instruction will always be followed or that adversarial language will always be ignored. This is not a criticism; it is an architectural fact. Consequently, the model should not be the final authority over rules that must hold without exception.

Critical financial limits should be enforced through deterministic controls outside the AI environment.

Examples include maximum transaction sizes, approved counterparties, operating hours, concentration limits, permissible instruments, deviation thresholds, and required approval levels. A model may explain a transaction, but it should not be able to redefine the rule that determines whether the transaction is permitted.

A simple control principle is:

If $|\Delta X| > L$, then block or escalate independently of the model.

Here, X can be a price, notional amount, risk limit, beneficiary instruction, or other financial state variable, while L is an independently defined tolerance.

The principle extends beyond numeric thresholds to database permissions, network segmentation, credential scopes, multi-party authorization, and approved-counterparty lists. The design objective is simple: the model must not be able to persuade the safety system to suspend the safety system [5, 4].

6 Provenance, Reconciliation, and Cryptographic Integrity

If integrity is central, institutions need independent mechanisms for verifying the state on which agents operate. Cryptographic hashing is one useful building block. A trusted reference file, configuration, or dataset can be represented by a checksum such as SHA-256. A later mismatch indicates that the underlying content has changed.

A hash does not reveal why data changed or whether the change was malicious; it shows that the state differs from the authenticated reference. Cyber controls often detect deviations rather than intentions.

Cryptographic checks should therefore be paired with independent reconciliation. Valuation outputs can be compared with approved pricing sources; payment instructions with authoritative beneficiary records; position changes with ledgers the agent cannot modify; and model memory with controlled reference data.

The strongest design uses **out-of-band verification**. Immutable or separately controlled logs should record model identity, instructions, sources, tool calls, approvals, exceptions, and final actions so that investigators can reconstruct events without relying on records the agent could alter.

7 A Pragmatic Protection Framework for Financial Institutions

The framework should be implemented as a connected control sequence rather than as a collection of isolated safeguards. It begins with the information entering the system, follows the agent through interpretation and tool use, and extends to authorization, monitoring, containment, and recovery. This creates a practical governance agenda for developers, risk managers, internal auditors, and senior executives [1, 2, 3, 5].

Segment inputs and identify untrusted information. Every source consumed by an agent should be mapped and classified. Emails, external documents, websites, vendor reports, customer submissions, and third-party research should be treated as untrusted until validated. Structured roles and controlled ingestion pipelines can reduce ambiguity, but prompt-level instructions to ignore embedded commands remain only one defensive layer.

Once inputs have been classified, institutions should **separate tool availability from tool authority**. An agent may need access to a tool without needing authority to execute an action. Read access to a portfolio database does not imply write access, and examining payment data does not imply the ability to release funds. Credentials should therefore follow least privilege, with higher-risk actions routed through separate authorization paths unavailable to the model.

That authority boundary should be reinforced by **isolated execution environments**. Systems that parse external files, run generated code, or perform exploratory analysis should be sandboxed from production infrastructure. Network access, filesystem permissions, credentials, and persistence should be minimized so that a compromised task cannot readily become an institutional compromise.

Before any proposal can alter financial state, institutions should **establish deterministic safety gates**. Hard-coded rules should enforce deviation tolerances, transaction caps, permissible counterparties, allowed instruments, operating windows, and escalation requirements. Out-of-bounds requests should fail safely rather than becoming subjects for conversational interpretation.

When a decision crosses a material threshold, **human approval must be economically meaningful**. Reviewers need enough context to understand the source, proposed action, deviation from the authenticated state, and expected financial effect. Material changes should require active or multi-party approval, while low-value alerts should be reduced so that attention remains available for consequential exceptions.

The same control discipline must extend across time through measures that **protect memory and state**. Agent memory should be governed as a controlled database rather than as an informal continuation of a conversation. External documents should not write persistent assertions directly into long-term memory, and retained state should have provenance, versioning, access controls, validation, and rollback.

Because no individual control is conclusive, institutions should also **maintain immutable external logging**. Agent activity should be observable from outside the agent through records of instructions, sources, tool calls, proposed outputs, approvals, policy triggers, blocked actions, and final outcomes. Security teams must be able to revoke access and investigate an event without relying on records the model could alter.

Finally, institutions should **build containment and recovery before scaling autonomy**. No design should assume perfect detection. Mature architectures use aggregate caps, operating windows, approved destinations, credential revocation, kill switches, rollback where feasible, trusted backups, and forensic reconstruction. Together, these controls constrain the agent before action, monitor it during operation, and preserve the institution's ability to stop and recover when prevention fails [3, 6, 8].

8 The Executive Governance Agenda

The board-level question is not “Is the model safe?” That question is too broad and, in practice, impossible to answer with certainty. The more useful questions are architectural:

1. What information can the agent read, and which sources are untrusted?
2. What persistent memory does it retain?
3. What tools can it call?
4. Which of those tools can create direct financial consequences?
5. What controls operate independently of the model?
6. Which actions require deterministic blocking or escalation?
7. What evidence does a human reviewer see before approving?
8. How are critical outputs reconciled against authoritative sources?
9. Where are logs stored, and can the agent alter them?

10. What are the hard monetary, temporal, and operational limits?
11. Who has immediate revocation authority?
12. Can the institution reconstruct the sequence of a compromise?
13. Can trusted financial state be restored rapidly?

These questions transform AI governance from an abstract discussion about model intelligence into a concrete discussion about institutional control [1, 7].

9 Implications for Master of Finance Students

For finance students, agentic cybersecurity is best understood as an extension of market, model, and operational risk. The familiar disciplines still apply: identify the state variable, map the transmission mechanism and loss distribution, define limits, separate duties, reconcile independently, and plan for stress.

The novel element is that the decision engine is partially cognitive: it reads, interprets, remembers, and may act. Emails, research reports, narrative instructions, and model memory can therefore become economically significant control inputs. Future financial professionals must ask not only whether a model produces good analysis, but whether the architecture preserves fiduciary control when the model is wrong, manipulated, unavailable, or compromised.

10 Conclusion: Intelligence Without Unbounded Authority

Agentic AI is likely to become deeply embedded in finance because it expands analytical capacity and lowers the cost of repetitive cognitive work. Yet the cybersecurity perimeter now includes language, context, memory, tools, and autonomous decision rights in addition to software and credentials.

The most important strategic principle is therefore the separation of **intelligence** from **authority**. AI can analyze, detect, summarize, propose, and explain. Deterministic systems and accountable humans should retain control over material actions, especially where failure can transfer value or corrupt authoritative state.

Four rules summarize the framework:

- **Prioritize integrity.** Protect the correctness and provenance of prices, positions, instructions, limits, and financial records.
- **Constrain the blast radius.** Use least privilege, sandboxing, scoped credentials, and segmented networks.
- **Externalize critical controls.** Keep transaction limits, authorization rules, reconciliation, and immutable logs outside the model's influence.
- **Design for containment and recovery.** Assume that prevention will sometimes fail and ensure that the institution can stop, isolate, reconstruct, and restore.

The age of agentic AI does not eliminate traditional cyber risk. It adds a new layer in which the system can be influenced through the very information it is designed to understand. For financial institutions, the answer is not to avoid intelligent systems, but to surround them with stronger architecture, clearer authority boundaries, and more disciplined governance. The objective is to capture the speed and scale of machine intelligence without surrendering the independent control structures on which financial trust

ultimately depends.

References

- [1] Tabassi, E. (2023). *Artificial Intelligence Risk Management Framework (AI RMF 1.0)*. NIST AI 100-1. National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.AI.100-1>
- [2] Autio, C., Schwartz, R., Dunietz, J., Jain, S., Stanley, M., Tabassi, E., Hall, P., and Roberts, K. (2024). *Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile*. NIST AI 600-1. National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.AI.600-1>
- [3] Pascoe, C., Quinn, S., and Scarfone, K. (2024). *The NIST Cybersecurity Framework (CSF) 2.0*. NIST CSWP 29. National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.CSWP.29>
- [4] OWASP GenAI Security Project. (2026). *OWASP GenAI LLM Top 10 2026*. <https://genai.owasp.org/resource/owasp-genai-llm-top-10-2026/>
- [5] UK National Cyber Security Centre, US Cybersecurity and Infrastructure Security Agency, and international partners. (2023). *Guidelines for Secure AI System Development*. <https://www.ncsc.gov.uk/collection/guidelines-secure-ai-system-development>
- [6] Basel Committee on Banking Supervision. (2021). *Principles for Operational Resilience*. Bank for International Settlements. <https://www.bis.org/bcbs/publ/d516.htm>
- [7] Prudential Regulation Authority. (2023). *SS1/23: Model Risk Management Principles for Banks*. Bank of England. <https://www.bankofengland.co.uk/prudential-regulation/publication/2023/may/model-risk-management-principles-for-banks-ss>
- [8] European Parliament and Council of the European Union. (2022). Regulation (EU) 2022/2554 on digital operational resilience for the financial sector. *Official Journal of the European Union*, L 333. <https://eur-lex.europa.eu/eli/reg/2022/2554/oj/eng>
- [9] Greshake, K., Abdelnabi, S., Mishra, S., Endres, C., Holz, T., and Fritz, M. (2023). Not What You've Signed Up For: Compromising Real-World LLM-Integrated Applications with Indirect Prompt Injection. In *Proceedings of the 16th ACM Workshop on Artificial Intelligence and Security*. <https://doi.org/10.1145/3605764.3623985>
- [10] Debenedetti, E., Zhang, J., Balunović, M., Beurer-Kellner, L., Fischer, M., and Tramèr, F. (2024). Agent-Dojo: A Dynamic Environment to Evaluate Prompt Injection Attacks and Defenses for LLM Agents. In *Advances in Neural Information Processing Systems 37, Datasets and Benchmarks Track*. <https://openreview.net/forum?id=m1YYAQj03w>

Author: Alejandro Reynoso.

Use: Educational and pedagogical discussion only.